

API Authentication

Tokens, OAuth 2.0, JWT and access control for APIs.

Authentication vs authorization

Authentication proves identity; authorization determines what that identity may access.

OAuth 2.0 and tokens

Access tokens are common in modern APIs. QA should validate missing, invalid and expired tokens, incorrect scopes and refresh flows where applicable.

JWT

JWT is a token format. Validate signature, expiration, claims and API behavior; decoding the payload alone does not prove validity.

When to use it

Use this knowledge when product risk, architecture or the delivery stage requires this type of validation. Confirm the goal, environment, required data and expected evidence before starting.

How QA applies it

Start from the behavior or risk to validate, prepare data and environment, execute the technique or tool reproducibly and capture evidence that helps the team understand the result.

Good practices

Prioritize high-impact scenarios, keep data and environments controlled, record important decisions and review the approach periodically to avoid redundant or outdated coverage.

QA tip

Always connect the practice to product risk and the evidence needed for quality decisions.

Official resources

Site oficial: <https://datatracker.ietf.org/doc/html/rfc6749>